

Nmap Scan Report

1. Executive Summary

This assessment involved scanning the Metasploitable2 virtual machine (**target: 192.168.23.128**) from a Kali Linux attacker host over an isolated host-only VMware network. The scan identified a large number of open TCP ports running outdated, unpatched, and often misconfigured services — several with known critical vulnerabilities (e.g., backdoored FTP, weak/legacy remote access protocols, outdated database and RPC services). The overall attack surface is extremely large and representative of a deliberately vulnerable training target rather than a production system. Findings support the conclusion that, if this configuration existed in a real environment, it would represent a critical risk requiring immediate remediation.

2. Scope

Field	Value
Scanner	Kali Linux
Target	Metasploitable2
Target IP	192.168.23.128
Network	Host-only VMware network
Date	11-09-2026

3. Methodology

Command	Purpose
<code>nmap -sn 192.168.23.0/24</code>	Host discovery (ping sweep) to confirm target is live
<code>nmap -sS 192.168.23.130</code>	TCP SYN (stealth) scan — identify open TCP ports
<code>nmap -sU 192.168.23.130</code>	UDP scan — identify open UDP ports
<code>nmap -sV 192.168.23.130</code>	Service/version detection on discovered ports

Command

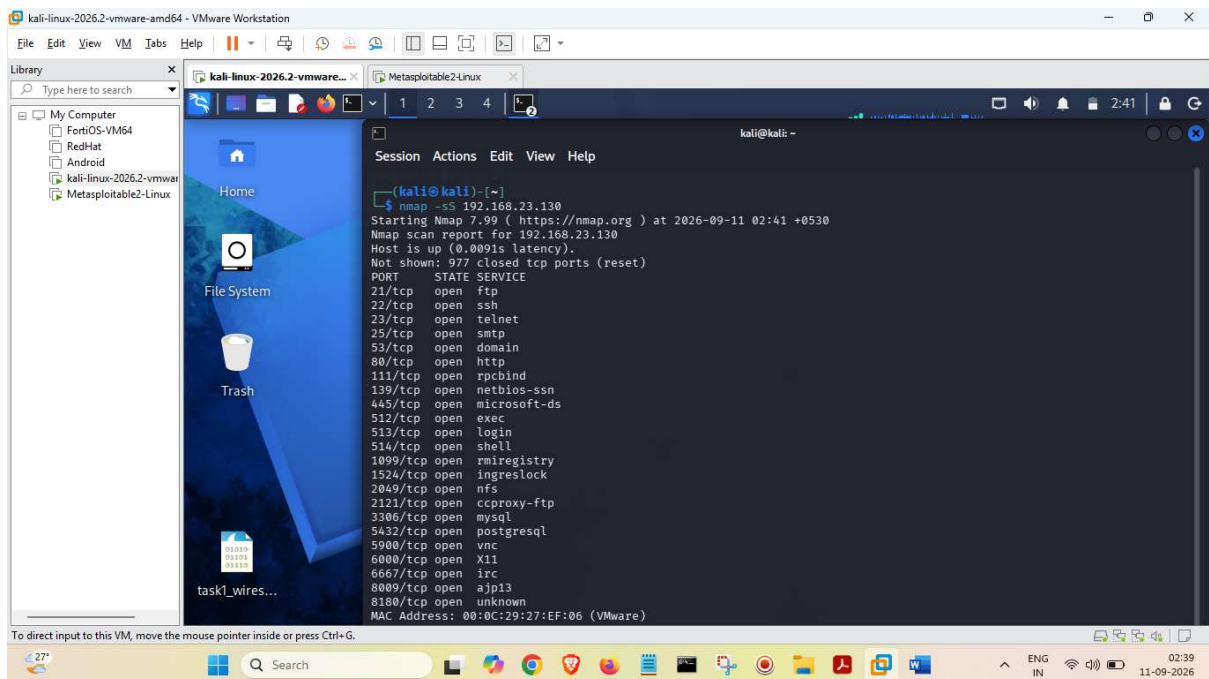
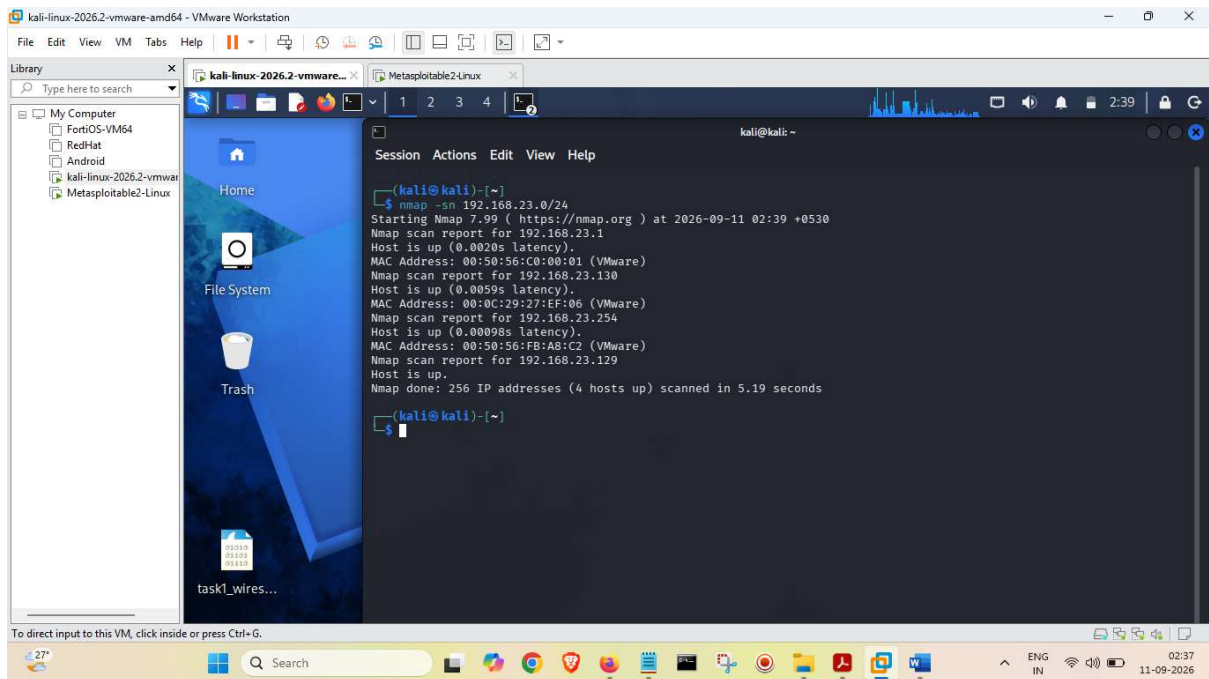
`nmap -O 192.168.23.130`

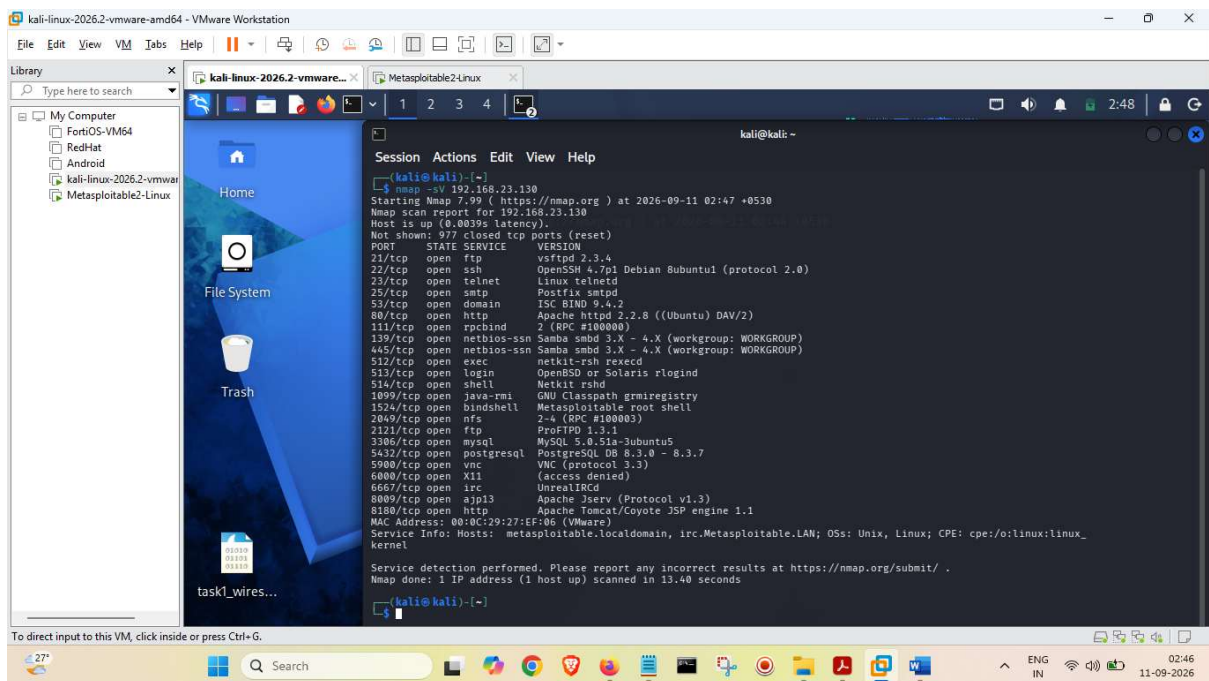
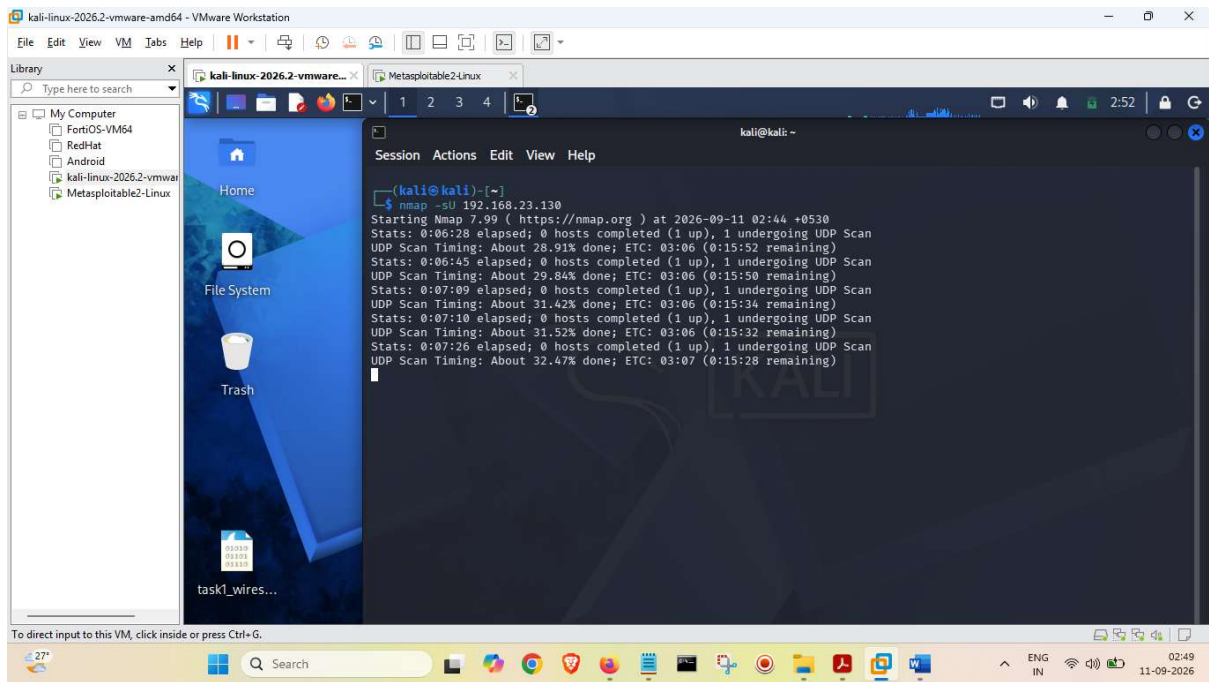
Purpose

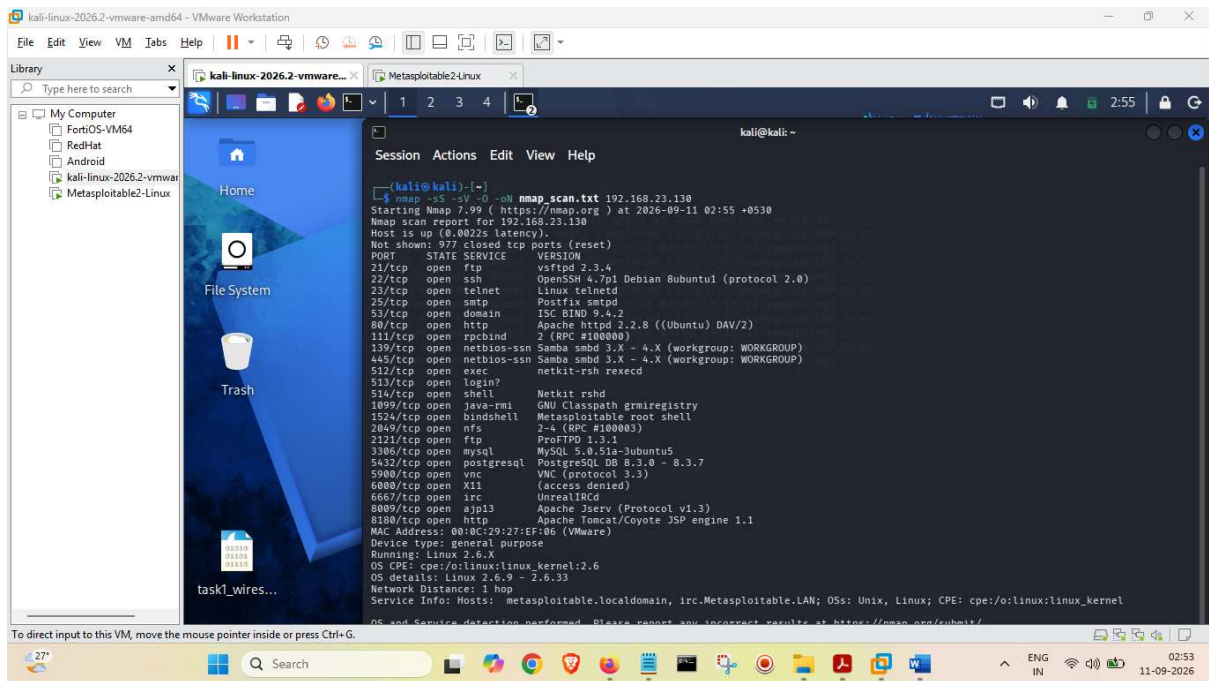
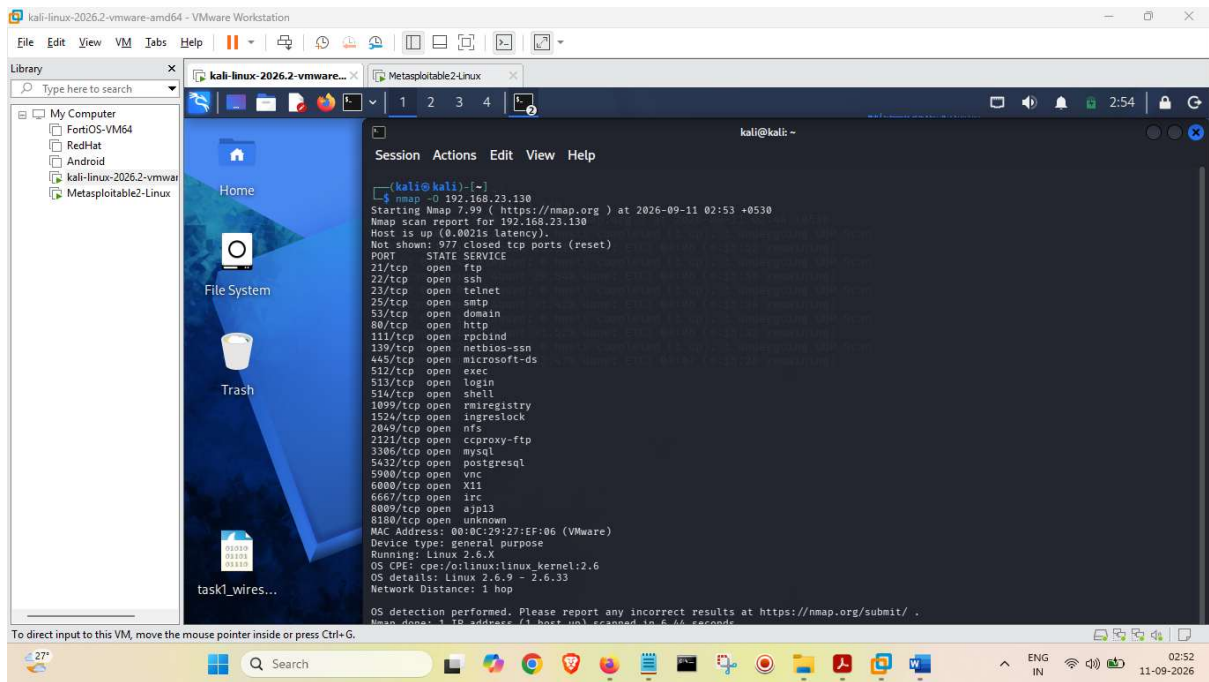
OS fingerprinting

`nmap -sS -sV -O -oN nmap_scan.txt`
`192.168.23.130`

Combined scan with output saved to file







4. TCP Findings

Port State Service

21 open ftp

Port	State	Service
------	-------	---------

22	open	ssh
23	open	telnet
25	open	smtp
53	open	domain
80	open	http
111	open	rpcbind
139	open	netbios-ssn
445	open	netbios-ssn (samba)
512	open	exec
513	open	login
514	open	shell
1099	open	rmiregistry
1524	open	ingreslock (backdoor shell)
2049	open	nfs
2121	open	ftp (ProFTPD)
3306	open	mysql
3632	open	distccd
5432	open	postgresql
5900	open	vnc
6000	open	X11
6667	open	irc
8009	open	ajp13
8180	open	http (Tomcat)

5. UDP Findings

UDP scans on this target typically return few/no clearly "open" results — mostly open|filtered due to Nmap's UDP scanning limitations (no response ≠ closed). Common candidates: 53/udp (domain), 111/udp (rpcbind), 137/udp (netbios-ns).

6. Service-Version Findings (from -sV, expected examples)

Port	Service	Version (typical)
21	ftp	vsftpd 2.3.4 (known backdoored version)
22	ssh	OpenSSH 4.7p1 Debian
23	telnet	Linux telnetd
25	smtp	Postfix smtpd
80	http	Apache 2.2.8 (Ubuntu)
3306	mysql	MySQL 5.0.51a-3ubuntu5
5432	postgresql	PostgreSQL 8.3.0-8.3.7
8180	http	Apache Tomcat/Coyote JSP engine 1.1

7. OS Detection

Metasploitable2 typically fingerprints as an older Linux kernel (2.6.x).

8. Risk Analysis

Finding	Severity	Justification
vsftpd 2.3.4 on port 21	Critical	Known backdoored version allowing remote command execution
ingreslock backdoor (1524)	Critical	Direct root shell with no authentication
distccd (3632)	Critical	Known RCE vulnerability (CVE-2004-2687)
Telnet (23)	High	Unencrypted credentials/session, legacy protocol

Finding	Severity	Justification
rlogin/rsh (512-514)	High	Unauthenticated/weak-auth remote shell access
UnrealIRCd-style/IRC (6667)	High	Historically backdoored builds enable RCE
Samba (139/445)	High	Older Samba versions vulnerable to known RCE
MySQL/PostgreSQL exposed	Medium	Databases exposed to network; risk depends on auth strength
Apache Tomcat (8180)	Medium	Default/weak manager credentials often enable WAR deployment RCE
NFS (2049)	Medium	Misconfigured exports can allow unauthorized file access
SSH (22)	Low	Outdated version, but requires valid credentials
HTTP (80)	Low-Informational	Depends on hosted application; assess separately
Open port count/attack surface	Informational	Broad exposure increases overall risk profile

9. Recommendations

- Disable/remove backdoored and legacy services (**vsftpd 2.3.4, ingreslock, distccd**) entirely.
- Replace **Telnet, rlogin/rsh** with **SSH**; disable unencrypted management protocols.
- Patch or upgrade all identified services to current stable versions.
- Restrict database and **RPC services (MySQL, PostgreSQL, rpcbind, NFS)** to trusted internal hosts via firewall rules.
- Enforce strong authentication on **Tomcat manager** and remove default credentials.
- Apply **network segmentation** to isolate vulnerable hosts from production networks.
- Implement continuous **monitoring/logging (IDS)** for exposed services.
- **Conduct regular vulnerability scanning and re-testing after remediation.**

10. Conclusion

The scan of Metasploitable2 revealed an extensive attack surface consisting of numerous outdated, misconfigured, and in some cases intentionally backdoored services. Multiple critical vulnerabilities would allow trivial unauthenticated remote code execution in a real-world deployment. This exercise illustrates the importance of minimizing exposed services, maintaining current patch levels, and applying defense-in-depth controls such as segmentation and monitoring.